

# A-IDAPS-FL Phase 2 — Viva Question & Answer Addendum

Numbers refer to the report split of the CIC-IDS2017 hold-out (283,074 flows). Where a Phase 1 answer is now wrong, the corrected answer is given.

## Federated learning

---

**Q1. What does "federated" mean in your system?** Four independent node processes each hold their own traffic partition and train locally. Only model parameters (Autoencoder weights) or newly grown trees (XGBoost) are sent to the server over TLS. The server never receives a flow record, IP address or port.

**Q2. Which framework and why gRPC mode instead of simulation mode?** Flower 1.36. Simulation mode runs clients as Ray actors in one process and cannot use TLS; deployment mode runs real gRPC clients, which lets us demonstrate encrypted transport and a genuine server/node separation.

**Q3. How do you aggregate the Autoencoder?** FedAvg: the server averages the four weight vectors, each weighted by the node's number of benign training rows, then sends the average back.

**Q4. Trees cannot be averaged. How do you federate XGBoost?** Bagging (Flower `FedXgbBagging`). Each round every node loads the global booster, grows three more trees on its own data, and sends back only those trees. The server appends all twelve to the global booster. After 40 rounds the global model has 480 trees.

**Q5. What went wrong with bagging on your data and how did you fix it?** Nodes 2 and 3 hold almost no attacks, so their trees push probabilities down every round. Ranking stays excellent (AUC 0.9998) but at a fixed 0.5 cutoff recall was only 27%. The server calibrates the cutoff on its own labelled calibration split (chosen 0.164), restoring 99.95% recall at 0.25% FPR.

**Q6. Isn't calibrating on the test set cheating?** The hold-out is split into a calibration half (even rows) and a report half (odd rows). Thresholds are chosen on the first, every reported number comes from the second.

**Q7. What is non-IID data and how did you create it?** Nodes see different distributions: node 0 only DDoS/DoS attacks, node 1 PortScan/Bot, node 2 BruteForce/WebAttack, node 3 almost only benign traffic. This mimics organisations with different threat exposure and is the hard case for federated learning.

## Results

---

**Q8. Federated vs centralized: who wins?** Centralized hybrid 99.55% accuracy / 99.68% recall / 0.49% FPR; federated 99.23% / 99.95% / 0.95%. Centralized needs 2.26 million raw flows uploaded; federated needs zero. Federated is better on the rare families (Bot 97.5% vs 66.8%, WebAttack 99.5% vs 60.0%) because per-node class weighting and the calibrated cutoff favour minority attacks.

**Q9. How does this compare with Phase 1?** The Phase 1 model on the same multi-attack data: 88.92% accuracy, 51.75% recall. It detected 5% of port scans and 0.1% of brute-force flows because it was trained on the DDoS day only.

**Q10. Is 99% accuracy overfitting?** The report half was never used for training or tuning; node partitions and the hold-out are disjoint; XGBoost uses subsampling and column sampling; the result holds across seven attack families with different mechanisms. The remaining error is mostly autoencoder false positives (0.95% FPR).

## Privacy and security

---

**Q11. Did differential privacy work?** The mechanism works end to end (clip each client update to norm  $C$ , add Gaussian noise  $z \cdot C/4$ ) but with only four clients it is not useful: noise strong enough for  $\epsilon < 10$  destroys the model, and the noise level at which the model still trains ( $z = 0.01$ ) gives  $\epsilon \approx 2 \times 10^5$ , which is no privacy. DP-FedAvg needs hundreds of clients so the noise averages out. We report this as a negative result.

**Q12. Then where does privacy come from?** From the architecture: raw traffic never leaves a node, only parameters do, and the channel is TLS. Model parameters can still leak information in principle (membership inference), which is exactly what DP would address with more clients.

**Q13. How is TLS set up?** `federated/gen_certs.py` creates a root CA and a server certificate for `localhost/127.0.0.1`. The server presents the certificate; clients verify it against the CA. Client authentication keys are listed as future work.

## Explainability

---

**Q14. What explanations does the dashboard show?** For the last alert or simulated flow: exact TreeSHAP contributions of the XGBoost decision, the share of autoencoder reconstruction error per feature, and optionally a LIME-style local linear surrogate of the final hybrid score (500 perturbations, proximity-weighted ridge regression, with  $R^2$ ).

**Q15. SHAP vs LIME?** SHAP values are exact for the tree model and sum to the model output. LIME is model-agnostic, so it explains the whole max-rule including the autoencoder, but it is an approximation whose quality is shown by the local  $R^2$ .

## Prevention

---

**Q16. Does the system block attackers?** Yes, when enabled. A public source is blocked after three flows scoring  $\geq 0.75$  within 60 seconds, via a Windows Firewall or iptables rule. Default is dry-run (decision logged, nothing changed). Private and local addresses and the simulator are never blocked; every action is audited and can be undone from the dashboard.

## Temporal model

---

**Q17. Why isn't the LSTM used in production?** On 10-flow chronological windows it scored 88.9% accuracy / 62.7% recall against 95.9% / 99.2% for the flow-level hybrid. Under a strict chronological split it failed on attack sub-variants it had not seen (FTP-Patator morning vs SSH-Patator afternoon). A longer, source-grouped sequence design is future work.

## Engineering

---

**Q18. What was wrong with the Phase 1 deployment?** `threshold.json` contained the ensemble cutoff 0.5 instead of the reconstruction threshold, so the deployed predictor had 0% recall; the live extractor used seconds and frame lengths where the dataset uses microseconds and payload bytes; dashboard metrics were partly hard-coded. All fixed in Phase 2 and covered by a regression test that replays real flows.

**Q19. How do you know the code still works after a change?** 16 pytest tests: extractor units, the pure decision rule, a replay of 20,000 real flows with recall and FPR floors per family, prevention policy, DP accounting, event store, LIME.

**Q20. Communication overhead?** Autoencoder: 117 KB per node per round, 14 MB total. XGBoost: 257 MB total because the growing 3.1 MB booster is redistributed every round; sending only per-round deltas would reduce this to about 12 MB. Total is comparable to a one-time upload of the raw data (274 MB) but contains no traffic.